

## 7. Scan passivo com OWASP ZAP

Fiz um scan passivo manual com o OWASP ZAP (versão 2.17) na API rodando localmente em `http://127.0.0.1:8000`. Usei a opção Manual Explore abrindo o `/docs` pelo navegador do ZAP e chamei as rotas pelo Swagger: GET `/health`, POST `/auth/token` (com senha errada e com senha certa), POST `/predict` com token e POST `/predict` sem token.

Para analisar só a API, incluí `http://127.0.0.1:8000.*` no contexto e filtrei o History e os Alerts para mostrar só as URLs desse contexto.

O ZAP encontrou 9 alertas: 1 High, 4 Medium, 1 Low e 3 Informational. O relatório de findings foi exportado em `zap_report_antes.html` (Traditional HTML Report). Abaixo estão documentados os findings com severidade Medium ou High.

### Finding 1 — Authentication Credentials Captured

|                                     |                                                                                                                                                                                                                                                                                                                 |
|-------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 7.1. Finding                        | Authentication Credentials Captured                                                                                                                                                                                                                                                                             |
| 7.2. Severidade                     | High                                                                                                                                                                                                                                                                                                            |
| 7.3. Confiança                      | Medium                                                                                                                                                                                                                                                                                                          |
| 7.4. URL afetada                    | <code>http://127.0.0.1:8000/auth/token</code>                                                                                                                                                                                                                                                                   |
| 7.5. O que foi detectado            | O ZAP identificou que o POST <code>/auth/token</code> recebe as credenciais (usuário e senha) por HTTP, sem criptografia. Também foi detectado o envio de um header <code>Authorization: Basic</code> , que o Swagger manda no fluxo OAuth2 password.                                                           |
| 7.6. Por que é um problema          | Como a comunicação é em HTTP, qualquer pessoa na mesma rede pode capturar o tráfego e ler o usuário e a senha. No Basic Authentication as credenciais ficam só em base64, que é fácil de decodificar (CWE-287, OWASP A02:2017 Broken Authentication).                                                           |
| 7.7. Correção realizada             | Não foi corrigido no ambiente local.                                                                                                                                                                                                                                                                            |
| 7.8. Validação                      | Não se aplica, pois o finding não foi corrigido.                                                                                                                                                                                                                                                                |
| 7.9. Risco aceito, se não corrigido | A API roda só localmente ( <code>127.0.0.1</code> ), em ambiente de desenvolvimento, então o tráfego não passa pela rede. A correção indicada pelo ZAP é usar HTTPS, o que precisa de certificado e é configurado no deploy (servidor ou proxy reverso com TLS). Em produção a API deve rodar somente em HTTPS. |

### Finding 2 — CSP: Failure to Define Directive with No Fallback

|                 |                                                   |
|-----------------|---------------------------------------------------|
| 7.1. Finding    | CSP: Failure to Define Directive with No Fallback |
| 7.2. Severidade | Medium                                            |
| 7.3. Confiança  | High                                              |

|                                            |                                                                                                                                                                                                                                                                                                                                                                         |
|--------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>7.4. URL afetada</b>                    | http://127.0.0.1:8000/docs                                                                                                                                                                                                                                                                                                                                              |
| <b>7.5. O que foi detectado</b>            | O header Content-Security-Policy do /docs não define a diretiva form-action. Essa diretiva não herda o valor do default-src, então quando não é definida fica tudo liberado.                                                                                                                                                                                            |
| <b>7.6. Por que é um problema</b>          | Sem form-action um formulário da página pode enviar dados para qualquer destino, inclusive um site do atacante, caso algum conteúdo malicioso seja injetado na página (CWE-693, falha no mecanismo de proteção).                                                                                                                                                        |
| <b>7.7. Correção realizada</b>             | Não foi corrigido.                                                                                                                                                                                                                                                                                                                                                      |
| <b>7.8. Validação</b>                      | Não se aplica, pois o finding não foi corrigido.                                                                                                                                                                                                                                                                                                                        |
| <b>7.9. Risco aceito, se não corrigido</b> | O alerta aparece só na página /docs, que é o Swagger UI gerado pelo FastAPI e usado em desenvolvimento. Essa página não tem formulários HTML que enviam dados para outros destinos, e as rotas da API devolvem só JSON. A correção seria adicionar form-action 'self' na CSP do middleware, ou desligar o /docs em produção com FastAPI(docs_url=None, redoc_url=None). |

### Finding 3 — CSP: script-src unsafe-inline

|                                            |                                                                                                                                                                                                                                                                                                                                                                                                                 |
|--------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>7.1. Finding</b>                        | CSP: script-src unsafe-inline                                                                                                                                                                                                                                                                                                                                                                                   |
| <b>7.2. Severidade</b>                     | Medium                                                                                                                                                                                                                                                                                                                                                                                                          |
| <b>7.3. Confiança</b>                      | High                                                                                                                                                                                                                                                                                                                                                                                                            |
| <b>7.4. URL afetada</b>                    | http://127.0.0.1:8000/docs                                                                                                                                                                                                                                                                                                                                                                                      |
| <b>7.5. O que foi detectado</b>            | A CSP da página /docs tem 'unsafe-inline' na diretiva script-src, ou seja, permite rodar scripts escritos direto no HTML.                                                                                                                                                                                                                                                                                       |
| <b>7.6. Por que é um problema</b>          | Com 'unsafe-inline' a CSP perde boa parte da proteção contra Cross-Site Scripting (XSS), porque um script injetado na página também seria executado (CWE-693).                                                                                                                                                                                                                                                  |
| <b>7.7. Correção realizada</b>             | Não foi corrigido.                                                                                                                                                                                                                                                                                                                                                                                              |
| <b>7.8. Validação</b>                      | Não se aplica, pois o finding não foi corrigido.                                                                                                                                                                                                                                                                                                                                                                |
| <b>7.9. Risco aceito, se não corrigido</b> | A página /docs é o Swagger UI gerado pelo FastAPI, e ele usa um script inline para iniciar a interface. Sem 'unsafe-inline' o Swagger fica em branco. O risco é aceito porque o alerta é só na página de documentação, que é usada em desenvolvimento e não exibe dados de usuário. As rotas da API devolvem só JSON. Em produção a documentação pode ser desligada com FastAPI(docs_url=None, redoc_url=None). |

#### Finding 4 — CSP: style-src unsafe-inline

|                                     |                                                                                                                                                                                                                                                    |
|-------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 7.1. Finding                        | CSP: style-src unsafe-inline                                                                                                                                                                                                                       |
| 7.2. Severidade                     | Medium                                                                                                                                                                                                                                             |
| 7.3. Confiança                      | High                                                                                                                                                                                                                                               |
| 7.4. URL afetada                    | http://127.0.0.1:8000/docs                                                                                                                                                                                                                         |
| 7.5. O que foi detectado            | A CSP da página /docs tem 'unsafe-inline' na diretiva style-src, permitindo estilos escritos direto no HTML.                                                                                                                                       |
| 7.6. Por que é um problema          | Estilos inline liberados permitem injeção de CSS, que pode ser usada para mudar a aparência da página e enganar o usuário ou, em alguns casos, vazam informações da página (CWE-693).                                                              |
| 7.7. Correção realizada             | Não foi corrigido.                                                                                                                                                                                                                                 |
| 7.8. Validação                      | Não se aplica, pois o finding não foi corrigido.                                                                                                                                                                                                   |
| 7.9. Risco aceito, se não corrigido | O Swagger UI usa estilos inline e não funciona corretamente sem 'unsafe-inline' no style-src. Assim como no finding anterior, o alerta é só na página /docs, usada em desenvolvimento, e pode ser eliminado em produção desligando a documentação. |

#### Finding 5 — Sub Resource Integrity Attribute Missing

|                                     |                                                                                                                                                                                                                                                   |
|-------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 7.1. Finding                        | Sub Resource Integrity Attribute Missing                                                                                                                                                                                                          |
| 7.2. Severidade                     | Medium                                                                                                                                                                                                                                            |
| 7.3. Confiança                      | High                                                                                                                                                                                                                                              |
| 7.4. URL afetada                    | http://127.0.0.1:8000/docs (2 ocorrências: o swagger-ui.css e o swagger-ui-bundle.js carregados do cdn.jsdelivr.net)                                                                                                                              |
| 7.5. O que foi detectado            | A página /docs carrega o CSS e o JavaScript do Swagger de um CDN externo sem o atributo integrity nas tags <link> e <script>.                                                                                                                     |
| 7.6. Por que é um problema          | Sem o integrity o navegador não confere se o arquivo baixado do CDN é o original. Se o CDN fosse comprometido, um arquivo alterado com código malicioso seria executado na página (CWE-345, verificação insuficiente da autenticidade dos dados). |
| 7.7. Correção realizada             | Não foi corrigido.                                                                                                                                                                                                                                |
| 7.8. Validação                      | Não se aplica, pois o finding não foi corrigido.                                                                                                                                                                                                  |
| 7.9. Risco aceito, se não corrigido | O HTML do /docs é gerado automaticamente pelo FastAPI, que não coloca o atributo integrity. O cdn.jsdelivr.net é um CDN conhecido e a página é usada só em desenvolvimento. Para corrigir,                                                        |

|  |                                                                                                          |
|--|----------------------------------------------------------------------------------------------------------|
|  | seria preciso servir os arquivos do Swagger localmente pela própria API ou desligar o /docs em produção. |
|--|----------------------------------------------------------------------------------------------------------|